

Module 1 - Introduction to ISO 27001

1. Is ISO 27001 a standard that defines the technical details for information security, e.g., how to configure a firewall?
 1. **No – Correct!**
 2. **Yes – Incorrect!** ISO 27001 specifies the requirements for establishing, implementing, and maintaining information security in organizations. It specifies what needs to be achieved; it doesn't specify any technical details of how things should be done.
2. Why is the Planning section described before the Operation section in the standard?
 1. **The sequence doesn't have any meaning – Incorrect!** Operations are more efficient when properly planned.
 2. **It is logical that way – Incorrect!** Operations are more efficient when properly planned.
 3. **In order to have efficient operations, you need to plan them first – Correct!**
 4. **The Planning section is not described before the Operation section – Incorrect!** The Planning section is described before the Operation section, and operations will use the controls planned in the Planning section.
3. For the following security controls, choose which of the three information security principles (confidentiality, integrity, and availability) they impact most:
 1. Availability - Backup of information – In cases when information is deleted or corrupted for some reason, the information is no longer available to the organization. The backup enables the availability of the information.
 2. Integrity - Anti-virus software – A virus is software that can corrupt the information by modifying it. Installing anti-virus programs protects the integrity of the information.
 3. Confidentiality - Safe or lockbox – Locking paper-based documents in a safe or lockbox protects the confidentiality of the information in the document.
4. Identify which of the following information security controls are organizational controls:
 1. **Defining a policy on the use of cryptographic controls – Incorrect!** A policy on the use of cryptographic controls is a technological control.
 2. **Documenting a clear screen policy – Incorrect!** A clear screen policy is physical control.
 3. **Training employees how to use cryptographic controls – Incorrect!** Training is an HR control.
 4. **Documenting a procedure for training employees – Correct!**
5. Choose which of the following activities are parts of the Plan phase:
 1. **Conducting the internal audit – Incorrect!** The internal audit is an activity from the Check phase.

2. Implementation of the Risk treatment plan – Incorrect! The implementation of the risk treatment plan is an activity from the Do phase.

3. Based on the results from the risk assessment choosing controls and documenting a Statement of Applicability – Correct!

4. Implementing improvements – Incorrect! The improvement initiatives are part of the Act phase.

6. The project manager, as one of the basic roles in the ISMS implementation process, has the following characteristics:

1. Provides relevant resources – Incorrect! Providing resources is the responsibility of the top management.

2. Sets the objectives of the project – Incorrect! Setting the objectives of the project is the responsibility of the top management.

3. Conducts the internal audit – Incorrect! The internal audit is conducted by the internal auditors, after the implementation process.

4. Is often the information security officer, as well – Correct!

7. How do you decide which policies and procedures to document?

1. It is a management decision; whatever top management decides will be documented – Incorrect! There are documents that are mandatory, required by the standard, and they have to be documented. Top management can decide about any additional documents.

2. Your certification auditor will identify this for you – Incorrect! Along with mandatory documents identified by ISO 27001, it is the decision of the organization if documentation will be necessary.

3. Check the risk assessment results to see if there is a need for such a control – Correct! If there is no risk, then you certainly won't need a document for it; if there is a risk, this still doesn't mean you have to write a document – you have to consider other criteria as well.

4. It depends on how many locations the company operates – Incorrect! The decision can depend on the size of the organization in general, but not strictly on the number of locations.

8. Which one of the following is a benefit of implementing an Information Security Management System based on ISO 27001 in an organization?

1. Improving the overall information security in your company – Correct!

2. Improving the company's manufacturing capabilities – Incorrect! Manufacturing capabilities are not directly influenced by ISO 27001.

3. Achieving compliance with local laws and regulations – Incorrect! ISO 27001 may contribute to compliance with some local laws and regulations, but it does not guarantee that your organization will comply with all local laws and regulations.

4. Guaranteeing the growth of your company – Incorrect! ISO 27001 might contribute to growth opportunities for the company, but it does not guarantee growth.

9. Information security and IT security refer to the same thing:

- 1. True – Incorrect!** Information security is wider than IT security, and includes protection of different kinds of information, not just information stored and transmitted over IT networks.
- 2. False – Correct!**

10. An Information Security Management System is a systematic approach for managing and protecting a company's information.

- 1. True – Correct!**
- 2. False – Incorrect!** An ISMS is a framework for systematic mitigation of security risks related to information.

11. The PDCA cycle is:

- 1. A method used for management review – Incorrect!** PDCA is a method used for implementation and maintenance of an Information Security Management System in organizations.
- 2. An international standard – Incorrect!** PDCA is a concept, not a standard.
- 3. A method used for implementation and maintenance of an Information Security Management System in organizations – Correct!**
- 4. A tool for conducting risk assessment – Incorrect!** PDCA is not related to risk assessment.

12. Which one of the following roles is common in the ISMS implementation process:

- 1. Project accountant – Incorrect!** Such role is not critical for the ISMS implementation process.
- 2. Top management – Correct!** The top management must support the process by showing commitment, setting objectives, making decisions, and most importantly – providing relevant resources such as assigning the right people to dedicate enough time for the implementation process, dedicating budget, etc.
- 3. HR Specialist – Incorrect!** Such role is not critical for the ISMS implementation process.
- 4. Project evaluator – Incorrect!** Such role is not critical for the ISMS implementation process.

13. Achieving compliance is one of the main benefits of implementing ISO 27001:

- 1. True – Correct!**
- 2. False – Incorrect!** ISO 27001 provides a methodology that helps companies comply with the relevant regulations regarding data protection, privacy, IT governance, etc.

Module 2 - The planning phase

14. Which of the following statements represents an external issue:

1. **Organizational culture – Incorrect!** This is an internal issue.
2. **Economic environment – Correct!**
3. **The structure of the company – Incorrect!** This is an internal issue.
4. **The business strategy – Incorrect!** This is an internal issue.

15. Match the following interested parties with their requirements:

1. A company that buys your services - Protecting their information and signing a nondisclosure agreement
2. A government agency for personal data protection - Compliance with the personal data protection law
3. The company that supplies you with the materials for your production - Paying them on time and for all the delivered goods, i.e., having correct and available information for your supplies and deadlines for payment

16. Which of the following statements describes an ISMS scope?

1. **Company X's ISO 27001 certificate is valid until November 22, 2028 – Incorrect!** The scope should include the services or products that the company provides, and the locations included in the scope.
2. **Company X has implemented ISO 9001 and ISO 27001 – Incorrect!** The scope should include the services or products that the company provides, and the locations included in the scope.
3. **The Information Security Management System (ISMS) applies to the provision of software development and implementation, as well as outsourcing of IT services including maintenance of hardware and software, operating from the offices in London and Edinburgh – Correct!**
4. **The ISMS has implemented all the controls from Annex A – Incorrect!** The scope should include the services or products that the company provides, and the locations included in the scope.

17. How can top management demonstrate leadership and commitment to the Information Security Management System?

1. **Documenting the information security policies and procedures – Incorrect!** Top management should approve the information security policies and procedures, but should not write them.
2. **Ensuring the resources necessary for the ISMS – Correct!**
3. **Creating exceptions to the security rules for top management – Incorrect!** Top management should set a good example for the rest of the employees by following the ISMS rules and communicating the importance of information security to all employees.

4. Dedicating one week a year for information security, while the rest of the time is dedicated to everyday activities – Incorrect! Top management should make sure that the ISMS is integrated within the company processes, not treat the ISMS as an isolated matter.

18. The following statements are requirements for the Information Security Policy:

1. It should include detailed information about the roles and responsibilities of the employees – Incorrect! This policy is a top-level policy, and it shouldn't be too detailed. The details about the employees' roles and responsibilities should be prescribed in detailed policies and procedures.

2. It should include relevant technical details and security rules – Incorrect! This policy is a top-level policy and it shouldn't be too detailed. The details about the information security controls and rules should be prescribed in detailed policies and procedures.

3. It should provide a framework for setting information security objectives – Correct!

4. It must include the ISMS scope – Incorrect! There is no such requirement for the Information Security Policy.

19. Which of the following responsibilities and authorities are relevant for the person responsible for reporting on the performance of the ISMS to top management?

1. Updating the Statement of Applicability – Incorrect! Updating the Statement of Applicability is ensuring that the ISMS fulfills the requirements of ISO 27001.

2. Training employees on ISMS rules – Incorrect! This is not a responsibility listed for the person reporting on ISMS performance.

3. Conducting a campaign for ISMS awareness raising – Incorrect! Awareness raising is ensuring that the ISMS fulfills the requirements of ISO 27001.

4. Measuring the KPIs (Key Performance Indicators) – Correct!

20. Which of the following objectives represents a measurable information security objective?

1. Ensure 99.9% availability of the company's services annually - Incorrect! This information security objective is too general and doesn't provide a measurable target.

2. Decrease the average time for solving incidents by 10% during the next 12 months - Correct!

3. Increase the information security awareness of employees - Incorrect! This information security objective is too general and doesn't provide a measurable target.

4. Strengthen the overall capabilities of the Information Security Management System in the next six months - Incorrect! This information security objective is too general and doesn't provide a measurable target.

21. For effective implementation of incident management software in Company Y, the following resources should be available:

1. Available person and time to conduct analysis of the most suitable software for incident management in Company Y – Incorrect!

2. Responsible person for coordinating the implementation of the procedure – Incorrect!
3. Available time for all employees to pass short training on how to use the incident management software for reporting incidents – Incorrect!
4. All of the above – Correct!

22. Which of the following statements represents requirements from the ISO 27001 standard?

1. All employees should have an ISO 27001 Introduction certificate - Incorrect! The standard requires the company to determine the necessary competencies; it doesn't indicate specific competencies.
2. Keep records as evidence of competence – Correct!
3. Assign a security mentor to each employee – Incorrect! Mentors are not the only method of building competencies.
4. All employees shall have university degrees – Incorrect! The standard requires the company to determine the necessary competencies; it doesn't indicate specific competencies.

23. Information security awareness raising helps employees become information security experts:

1. True – Incorrect! Awareness-raising campaigns help employees understand information security better, but that doesn't make them experts on the topic.
2. False – Correct!

24. Communication rules should cover the following elements:

1. When the scheduled internal audit is scheduled – Incorrect! This is an important message to be communicated; however, it is not a rule for communication.
2. What should be communicated – Correct!
3. Standard form for communication for each media used (e.g., social media, press, television, etc.) – Incorrect! This is an important item to ensure aligned communication; however, it is not a rule for communication.
4. Why information security objectives are important – Incorrect! This is an important message to be communicated; however, it is not a rule for communication.

25. When creating a new document, you should take into consideration the following aspects:

1. Storing the document wherever is suitable for you - Incorrect! Documents should be stored as prescribed by the company; for example, electronic information is stored in shared folders on the company file server or in a folder in the cloud.
2. Adding in as many examples as you can – Incorrect! Too much information in a document can be as problematic as not enough information.
3. Saving the document in the appropriate file format – Correct!

4. The document is very well written, so it doesn't need a title. It is pretty much obvious what it is – Incorrect! A document title is probably the first thing that the readers are looking for.

26. ISO 27001 requires the identification of interested parties significant for the information security in your organization to be documented.

1. True – Incorrect! The standard requires these analyses to be conducted; however, it does not require them to be documented.

2. False – Correct!

27. In order to define the ISMS scope, the company should consider:

1. Biggest risks – Incorrect! The risks are assessed after the scope is set.

2. Activities that are carried out by your organization and the activities performed by other organizations, such as partners, associates, or an outsourcing company; how those activities are related; and how they depend on each other – Correct!

3. Information security objectives – Incorrect! The information security objectives are established after the scope is set, taking into consideration the defined scope.

4. The number of employees in the company – Incorrect! The number of employees doesn't influence the ISMS scope.

28. When defining the information security objectives, the following aspects should be taken into consideration:

1. They should be aligned with the Information Security Policy – Correct!

2. They should be documented together with the information security risk treatment – Incorrect! There is no such requirement in ISO 27001; objectives and the risk treatment plan are two separate documents.

3. They should include the amount of money that is saved by implementing the ISMS – Incorrect! There is no such requirement in ISO 27001.

4. They should be defined for a period of one year – Incorrect! The time frame for completion of objectives can be set by the company itself; it is not defined by the standard.

29. Regarding the resources, ISO 27001 requires companies to:

1. Group resources into three groups: financial, human, and time – Incorrect! ISO 27001 doesn't have such requirement; it refers to different types of resources.

2. Identify the necessary resources for the Information Security Management System – Correct!

3. Ensure only the necessary technical resources – Incorrect! ISO 27001 requires the companies to define the necessary financial resources, human resources, and so on.

4. Define an annual budget for the ISMS – Incorrect! ISO 27001 doesn't have such a requirement. The annual budget can be used as a tool for managing and controlling financial resources; however, it is not a requirement.

30. Regarding competencies, ISO 27001 requires the company to:

- 1. Send employees for training every month – Incorrect!** This is not a requirement from the standard.
- 2. Make sure that employees have the appropriate training and experience – Correct!**
- 3. Keep documented evidence for three years that the employees really have the required competencies – Incorrect!** The three-year period to keep evidence is not a requirement from the standard.
- 4. Send only the employees from the IT department to training – Incorrect!** The standard requires the company to ensure that all persons that can affect information security performance have the proper competence, through appropriate education, training, or experience.

Module 3 - Risk management

31. Risks and opportunities need to be addressed in order to:

- 1. Demonstrate management commitment – Incorrect!** Risks and opportunities should be addressed in order ensure an effective ISMS. Management should demonstrate commitment by conducting numerous relevant activities.
- 2. Ensure achievement of the ISMS outcomes – Correct!**
- 3. Prevent or reduce the financial and operational losses – Incorrect!** Risks and opportunities need to be addressed in order to prevent or reduce undesired effects, not only financial and operational losses.
- 4. Ensure all employees are aware of the risks and opportunities – Incorrect!** Risks and opportunities should be addressed in order ensure an effective ISMS.

32. Arrange in the appropriate order the steps from the risk management process:

- 1. Define the risk assessment methodology**
- 2. Conduct the risk assessment**
- 3. Select the risk treatment options**
- 4. Create the Statement of Applicability**
- 5. Create the risk treatment plan**

33. Which of the following represents assets from an information security perspective?

- 1. Key people leaving the company – Incorrect!** This is a threat.
- 2. Unauthorized modification – Incorrect!** This is a threat.
- 3. Software – Correct!**
- 4. Low awareness of information security – Incorrect!** This is a vulnerability.

34. For the cells that are empty in this Risk assessment table, match the correct answers below.

Assets	Risk Owner	Threats	Vulnerability	Impact (1-5)	Likelihood (1-5)	Risk (=I+L)
Laptop	Top management	(Cell 1)	(Cell 2)	3	(Cell 3)	6
Contract	Managing director	(Cell 4)	The contract is left on a table	4	3	7
System administrator	Department head	(Cell 5)	No one else knows the passwords, how to perform backup, etc.	5	4	(Cell 6)

1. Cell 1 - Stolen
2. Cell 2 - The laptop was left in a car
3. Cell 3 - 3
4. Cell 4 - Access by unauthorized persons
5. Cell 5 - Leave the company
6. Cell 6 - 9

35. Which of the following actions are accepted as good risk treatment practices?

1. Ignoring the risk – **Incorrect!** There are four options for risk treatment: applying controls to decrease the risk, avoiding the risk, accepting the risk, and risk transfer.
2. Risk sharing – **Incorrect!** There are four options for risk treatment: applying controls to decrease the risk, avoiding the risk, accepting the risk, and risk transfer.
3. Risk acceptance – **Correct!**
4. Doubling the risk – **Incorrect!** There are four options for risk treatment: applying controls to decrease the risk, avoiding the risk, accepting the risk, and risk transfer.

36. The Statement of Applicability document should include:

1. Only the controls from Annex A – **Incorrect!** The Statement of Applicability should list all the controls from Annex A and any additional controls that might be identified in the risk treatment process.
2. All the controls from Annex A and any additional controls that might be identified in the risk treatment process – **Correct!**
3. Only additional controls that might be identified in the risk treatment process – **Incorrect!** The Statement of Applicability should list all the controls from Annex A and any additional controls that might be identified in the risk treatment process.

4. The risk owner – Incorrect! This information should be included in the documents related to risks, not in the Statement of Applicability.

37. Which one of the following is a step in the risk management process:

1. Define the information Security Policy – Incorrect! This is a requirement from the standard but is not a part of the risk management process.

2. Create the risk treatment plan - Correct!

3. Understand the organization and its context – Incorrect! This is a requirement from the standard but is not a part of the risk management process.

4. Report the incidents to the top management – Incorrect! This is not a part of the risk management process.

38. According to ISO 27001, the risk assessment must include which one of the following elements:

1. Risk evaluation – Correct!

2. Risk transfer – Incorrect! Risk transfer represents a risk treatment option; it is not part of the risk assessment.

3. Risk treatment – Incorrect! Risk treatment is a requirement of the standard, but it is a step that comes after risk assessment; it is not part of the risk assessment process.

4. Defining the risk assessment methodology – Incorrect! Defining the risk assessment methodology is part of the risk management process, but it is not an element from the risk assessment; it is a step that comes before the risk assessment.

39. Risk analysis includes assessment of the impact the risk can have on the company and assessment of the likelihood that the identified risk could really happen. The assessment scale for the impact and the likelihood must vary between the values of 1 and 10.

1. True – Incorrect! Companies can choose different types of assessment scales for the impact and the likelihood, such as a “high, medium, and low” scale, or one with numerical values from 1 to 5, etc.

2. False – Correct!

40. After formulating a risk treatment plan, the Statement of Applicability must be documented.

1. True – Incorrect! First, the Statement of Applicability is documented, and after that, the risk treatment plan is formulated.

2. False – Correct!

41. The Statement of Applicability must include the following information:

1. The risk treatment option associated with each control from Annex A and any additional controls that might be identified in the risk treatment process – Incorrect! This information should be included in the risk treatment table, not in the Statement of Applicability.

2. Information regarding whether the listed controls are implemented in the organization – Correct!

3. The risk owner – Incorrect! This information should be included in the risk assessment table, not in the Statement of Applicability.

4. The value of the risk – Incorrect! This information should be included in the risk assessment table, not in the Statement of Applicability.

Module 4 - The Do phase

42. For the cells that are empty in this risk treatment plan, match the correct answers below.

Risk Treatment Plan			
Controls to be implemented	Reference to risks	Responsible person	Deadline
Document a back-up policy	(Cell 1)	Chief information security officer	March 2016
Implement the back-up policy	Risk no. 25 – Unavailability of electronic information because of accidental loss of the information	(Cell 2)	(Cell 3)
Implement a smart card physical entry control	(Cell 4)	Technical operations manager	April 2017
Buying a cabinet with a lock for protection of paper-based documents	(Cell 5)	Human resource manager	July 2016

1. Cell 1 - Risk no. 25 – Unavailability of electronic information because of accidental loss of the information

2. Cell 2 - System administrator

3. Cell 3 - June 2023

4. Cell 4 - Risk no. 32 – Laptops could be stolen by external people

5. Cell 5 - Risk no. 68 – Paper-based personnel files including personal data can be accessed by unauthorized employees

43. Choose which of the following statements can be documented as results for the follow-up from the implementation of a control-card-controlled access to the server room:

- 1. The internal audit is conducted – Incorrect!** This information is not relevant for this control.
- 2. Half of the people who work in the server room are trained in the use of the card readers – Incorrect!** All relevant people who require access to the server room need to be trained.
- 3. Analysis of the log and the video surveillance show that the card-controlled access to the server room is very effective – Correct!**
- 4. Cheaper equipment for card-controlled access than the one implemented is available on the market – Incorrect!** This information is not relevant and doesn't represent a result of the risk treatment.

44. ISO 27001 requires that every aspect of the ISMS should be documented.

- 1. True – Incorrect!** ISO 27001 doesn't specify that a document is needed for every single detail, but it points out that the organization should keep documented information in the amount necessary for that organization to make sure that the activities and controls are carried out as planned.
- 2. False – Correct!**

45. It is mandatory to change the ISMS documentation (modify, update, delete, add new documents, etc.) at least once per year:

- 1. True – Incorrect!** The documentation should be reviewed periodically to determine if a change is required; there is no schedule for making the changes.
- 2. False – Correct!**

46. Companies that have implemented ISO 27001 are not allowed to outsource critical operations, because that can have a negative impact on the information security.

- 1. True – Incorrect!** Outsourcing activities, especially those of critical operations, can have a negative impact on the ISMS; however, the standard doesn't forbid outsourcing of such activities. It simply requires that all outsourced operations are identified and appropriately controlled in regard to information security.
- 2. False – Correct!**

47. Changes in an organization can be planned and unplanned. Both types of changes should be controlled and their consequences reviewed.

- 1. True – Correct!**
- 2. False – Incorrect!** ISO 27001 requires companies to control planned changes and review the consequences of unintended change, while at the same time taking actions to mitigate unwanted effects.

48. According to you, which of the listed changes that can happen in a company may require conducting a re-assessment of risks?

1. Hiring a new employee – Incorrect! This is a very small and common change, and doesn't impact the information security significantly, so there isn't a need for conducting a re-assessment of risks.

2. Outsourcing the IT maintenance process to an IT company – Correct!

3. Buying new furniture – Incorrect! This is a very small and common change, and doesn't impact the information security significantly, so there isn't a need for conducting a re-assessment of risks.

4. Buying a new laptop for the office manager – Incorrect! This is a very small and common change, and doesn't impact the information security significantly, so there isn't a need for conducting a re-assessment of risks.

49. When implementing the information security risk treatment plan, one must:

1. Take into consideration available resources – Correct!

2. Document the information security risk treatment plan – Incorrect! After documenting the risk treatment plan, it should be executed by implementing the selected controls.

3. Re-assess the risks – Incorrect! This activity is prescribed by ISO 27001; however, it is not part of the risk treatment plan implementation.

4. Implement all controls from Annex A – Incorrect! Only the selected control stated as applicable in the Statement of Applicability needs to be implemented.

50. ISO 27001 requires companies to document the results of the risk treatment.

1. True – Correct!

2. False – Incorrect! The standard requires companies to keep documented information of the results of the information security risk treatment plan. These results are usually analyzed during every management review.

51. The Do phase moves companies from a stage where they plan information security to a stage where they implement information security and protect the information.

1. True – Correct!

2. False – Incorrect! In the Do phase, companies implement numerous information security controls, processes, and documents, and they put the ISMS into practice on a daily basis.

52. ISO 27001 requires the change management procedure to be documented.

1. True – Incorrect! ISO 27001 doesn't specify requirements for writing such a procedure.

2. False – Correct!

53. Operating an Information Security Management System (ISMS) means:

1. Auditing all of the activities described in the ISMS policies and procedures – Incorrect! Auditing is part of evaluating the performance of the ISMS, not operating it.

2. Producing ISMS records – Correct!

3. Certifying the ISMS – Incorrect! The ISMS should be operated on a daily basis, no matter whether the system is certified or not.

4. Maintaining highly detailed ISMS documentation – Incorrect! Short and brief documentation can also be maintained if it can provide confidence that activities can be performed as planned.

Module 5 - The Check and Act phases

54. ISO 27001 requires the chief information security manager to be responsible for monitoring and measurement of the ISMS.

1. True – Incorrect! Clause 9.2 from ISO 27001 requires companies to evaluate the ISMS by defining what needs to be monitored and measured, the methods for monitoring and analyses, who shall perform the monitoring and when, and who shall analyze the results and when.

2. False – Correct!

55. The main purpose of the internal audit is to help identify problems in the company and to identify who is responsible for those problems in order to initiate appropriate disciplinary actions.

1. True – Incorrect! The main purpose of the internal audit is to provide information on whether the ISMS is fulfilling the requirements of the company for information protection, and the requirements of ISO 27001.

2. False – Correct!

56. The purpose of the management review is to evaluate the results of the measurements and analyses and make crucial decisions.

1. True – Incorrect! The purpose of the management review is for top management to review the ISMS of the company at planned intervals in order to ensure it is suitable, adequate, and effective. Evaluation of the results of measurements and analyses is just one element of the management review.

2. False – Correct!

57. A nonconformity is when a certain incident happens in the organization.

1. True – Incorrect! A nonconformity is when a certain requirement is not complied with, such as a requirement from the ISO 27001 standard, relevant legislation, the ISMS documentation of the company, etc.

2. False – Correct!

58. ISO 27001 requires companies to continually improve:

1. The ISO 27001 standard by publishing new versions of the standard – Incorrect! ISO 27001 is published by the International Organization for Standardization (ISO), not by individual companies.

2. The suitability, adequacy, and effectiveness of the Information Security Management System – Correct!

3. The quality of the company's services – Incorrect! This is not a requirement of ISO 27001.

59. ISO 27001 requires companies to evaluate the information security performance and effectiveness of the ISMS through:

1. Mentoring – Incorrect! The standard requires evaluating the ISMS through monitoring, measuring, analysis, and evaluation. Mentoring isn't related to evaluation of the ISMS.

2. Awareness raising – Incorrect! The standard requires evaluating the ISMS through monitoring, measuring, analysis, and evaluation. Awareness raising is a requirement from the standard, but is not related to evaluation of the ISMS.

3. Measuring – Correct!

4. Implementation – Incorrect! The standard requires evaluating the ISMS through monitoring, measuring, analysis, and evaluation. Implementing security controls is a requirement from the standard, but is not related to evaluation of the ISMS.

60. As part of the process for evaluating the information security performance and effectiveness of the ISMS, ISO 27001 requires companies to:

1. Monitor and measure the incident management process – Incorrect! ISO 27001 doesn't specify what needs to be monitored and measured. It requires the company to define what needs to be monitored and measured.

2. Determine the methods for monitoring – Correct!

3. Document a procedure for the evaluation of ISMS effectiveness – Incorrect! ISO 27001 doesn't require such a procedure to be documented.

4. Nominate at least three responsible persons for conducting monitoring and measurements, so data tampering risk is reduced – Incorrect! ISO 27001 doesn't prescribe how many persons must be defined for conducting monitoring and measurement.

61. The objective of the internal audit is to identify who is responsible for the information security problems in the organization.

1. True – Incorrect! The objective of the internal audit is to identify nonconformities and initiate corrective actions, not to blame someone.

2. False – Correct!

62. ISO 27001 requires the top management to conduct management review meetings for reviewing the ISMS of the company.

1. True – Incorrect! ISO 27001 doesn't specify that a meeting should be conducted in order for top management to review the ISMS. The standard simply requires top management to review the ISMS of the company at planned intervals.

2. False – Correct!

63. In order for top management to review the suitability, adequacy, and effectiveness of the ISMS of the company, the following aspects should be covered:

1. **Opportunities for improvement – Correct!**

2. **Feedback from employees regarding the new cafeteria – Incorrect!** This kind of feedback is not the focus of the management review.

3. **An overview of the configuration parameters of the network router – Incorrect!** This is a technical matter regarding information security and is not relevant for management review.

4. **The financial status of the company – Incorrect!** The financial performance of the company is not the focus of the information security management review.

Module 6 - Overview of Annex A

64. All 93 controls listed in ISO 27001 Annex A must be implemented.

1. **True – Incorrect!** The controls listed in Annex A are not mandatory; a company can choose for itself which controls it finds applicable, and then it must implement them.

2. **False – Correct!**

65. The purpose of the A.6 People controls section of Annex A is:

1. **To punish people who don't follow the rules – Incorrect!** The disciplinary process is just one of the possible controls from this section; it is not the purpose.

2. **To help the company to employ high-quality people – Incorrect!** Only some of the controls refer to activities done prior to employment.

3. **To ensure that people working under the company understand and fulfill their information security responsibilities – Correct!**

4. **To prevent information disclosure by employees – Incorrect!** Only some of the controls refer to activities to prevent information disclosure.

66. Which of the following information security controls represent physical security controls?

1. **Public and private encryption keys – Incorrect!** These are technological controls related to cryptography.

2. **Ensuring the proper return of assets – Incorrect!** This is an organizational control.

3. **Securing equipment against theft when used outside of offices – Correct!**

4. **Defining guidelines for classification of information – Incorrect!** These are organizational controls related to asset management.

67. The technological controls from ISO 27001 Annex A are focused on the direct protection of data and information systems used.

1. **True – Correct!**

2. False – Incorrect! Controls A.8.10 (Information deletion) and A.8.11 (Data masking) define measures for data protection, while controls A.8.12 (Data leakage prevention), A.8.16 (Monitoring activities), and A.23 (Web filtering) define measures for protection of information systems.

68. To ensure that information security is integrated into the new information systems, companies should conduct the following activities:

1. Test the security features of the new systems – Correct!

2. Document a Change Management Policy – Incorrect! The standard doesn't specifically require documenting this policy.

3. Make updates on information systems as soon as vulnerabilities are identified – Incorrect! Modifications should be limited to those deemed necessary after a due risk analysis.

4. Identifying information security requirements for application services transactions is the job of the company that produces the information system, not the company that buys it – Incorrect! The information security requirements of different companies are different; that is why the company that buys a new system needs to identify the unique set of information security features required for that particular company.

69. Technological controls from ISO 27001 Annex A are those controls that are essential for ensuring secure operations of the IT infrastructure of the company.

1. True – Correct!

2. False – Incorrect! Technological controls from ISO 27001 Annex A are operational security controls crucial for ensuring secure IT operations, such as protection of malware, backup, logging, control of operational software, network, etc.

70. Information security should be addressed in every project, regardless of its type.

1. True – Correct!

2. False – Incorrect! Information security should be part of every phase of each project, internal and external.

71. According to ISO 27001, Annex A, information and assets should be managed by:

1. Defining a classification framework considering the levels Public, Internal, Confidential, and Top Secret – Incorrect! The standard doesn't prescribe specific levels of classification.

2. Defining expected behavior on the use of assets – Correct!

3. Implementing an asset management software – Incorrect! The standard doesn't prescribe asset management to be performed by a software tool.

4. By ensuring the former employee signs the Return of Asset form when leaving the organization – Incorrect! The standard doesn't prescribe a specific form to be signed.

72. According to ISO 27001, Annex A, operational security should be managed by:

- 1. Defining rules that will forbid access by third parties – Incorrect!** Third-parties may also have access to the organization's information, and such access also needs to be managed.
- 2. Defining how information can be transferred between organizations – Correct!**
- 3. Documenting procedures focusing only on employees from the IT department – Incorrect!** Documented procedures need to be understood the same way by users of all levels.
- 4. Having security documents not related to regular IT processes – Incorrect!** Information security needs to be embedded in regular IT processes and performed on a regular basis.

73. Security requirements can be agreed upon verbally with suppliers.

- 1. True – Incorrect!** Supplier agreements should be documented to make sure there is no misunderstanding between the company and the supplier regarding their information security obligations.
- 2. False – Correct!**

74. Management of information security incidents includes learning from the incidents.

- 1. True – Correct!**
- 2. False – Incorrect!** Knowledge gained from analyzing and resolving incidents should be used for learning from the incidents and reducing the chance of them reoccurring.

75. The controls related to compliance are focused primarily on avoiding breaches of intellectual property rights.

- 1. True – Incorrect!** Intellectual property is just one small aspect of compliance; the purpose of these controls is to ensure that information security is implemented as prescribed with the existing ISMS documentation of the company and to help companies avoid breaches of contractual and legal obligations connected to information security.
- 2. False – Correct!**

76. Controls related to information security policies require documenting a set of policies for defining information security rules. These policies are:

- 1. High-level policies that set the basic approach of the company for information security – Incorrect!** Annex A refers to low-level, topic-specific policies such as the Access Control Policy, Backup Policy, Policy for Classification of Information, Clear Desk and Clear Screen Policy, etc.
- 2. Mandatory – Incorrect!** The number of policies depends on the type of organization (size, complexity, industry, etc.).
- 3. Topic-specific policies – Correct!**
- 4. Updated at least once per year – Incorrect!** Annex A does not require updating the policies at least once per year; the company can decide on the frequency of updating the document, and the company must update the documents after significant changes in the organization.

77. The physical controls from section A.7 cover two sub-topics: controls for securing the area, and controls for securing the equipment.

1. True – Correct!

2. False – Incorrect! The sub-topic for securing areas focuses on preventing unauthorized physical access and damage to the information, and the sub-topic for securing the equipment focuses on preventing loss, damage, or compromise of assets.

78. Section A.5 Organizational controls requires documenting operational procedures that will be available to everyone in the organization who needs them.

1. True – Correct!

2. False – Incorrect! According to control A.5.37, companies should document procedures related to operational security, covering elements such as capacity management, controls against malware, backup, logging and monitoring, etc.

79. Section A.6 People controls aims to ensure that people are aware of their responsibilities regarding information security, have the necessary training, and will take proper measures to protect the information.

1. True – Correct!

2. False – Incorrect! People controls cover security practices from hiring to termination of employment, going through onboarding, awareness, development of competencies, and change of functions.

80. Section A.5 defines controls related to supplier management. These controls aim:

1. To ensure that failure to deliver reports as defined in agreements' clauses is properly handled – Incorrect! Supplier management aims to ensure that controls to treat risks related to suppliers are properly identified, agreed, monitored and reviewed.

2. To ensure that suppliers exceed the agreed levels of performance – Incorrect! Supplier management aims to ensure that controls to treat risks related to suppliers are properly identified, agreed, monitored and reviewed.

3. To ensure that controls to treat risks related to suppliers are properly identified, agreed, monitored, and reviewed – Correct!

4. To force suppliers to pay out damages that are incurred as a consequence of incidents – Incorrect! Supplier management aims to ensure that controls to treat risks related to suppliers are properly identified, agreed, monitored and reviewed.

Module 7 - Getting the project approved

81. Implementation of a management system will be the same, no matter whether you are working within a company or as a consultant.

1. Yes – Incorrect! Implementation steps will be different depending on your role.

2. No – Correct!

82. If you want more sales meetings you should develop your network of professional contacts.

1. True – Correct!

2. False – Incorrect! Your chances of success to get a sales meeting increase when you, or your work are known.

83. Usually, top management is interested in management system and certification.

1. False – Correct!

2. True – Incorrect! You have to show them how a management system and its certification are an instrument for them to get the results that is valuable for business, like profit and market share.

84. When presenting the project, you should focus on what the organization will get with the management system implementation.

1. True – Correct!

2. False – Incorrect! Remember, the company wants to know if this is the right step to be taken now and why.

85. Sometimes an ally, someone with influence over top management, with interest in a management system outcome can be crucial.

1. True – Correct!

2. False – Incorrect! Someone with influence over top management can know which lever to move to get their attention and interest.

86. Your proposal should state the resources that the organization must channel to the development of the project.

1. True – Correct!

2. False – Incorrect! They don't want surprises about resources needed after making the decision of going ahead with the project.

87. If you are a consultant, why would potential customers answer your call?

1. Because they heard about you and what results you bring – Correct!

2. Because they know how important a management system is – Incorrect! Most of the time potential customers do not know how important a management system can be important for them.

3. Because they have time to spare with you – Incorrect! Potential customers are always running out of time.

4. Because they have good manners – Incorrect! Potential customers appreciate much more their time than good manners.

88. Credibility and image can be a reason for implementing a management system.

1. True – Correct!

2. False – Incorrect! Many customers or potential customers include management system certification as part of their supplier requirements. Top management can evaluate lost business or potential business expansion due to system certification.

89. After sending a project proposal, you should wait for an answer.

1. True – Incorrect! You should show that you are interested without being too pushy and annoying.

2. False – Correct!

Module 8 - Prepare for the implementation

90. A multi-location organization must include all its activities in the scope of the management system.

1. False – Correct!

2. True – Incorrect! An organization can decide to include only some locations and activities in the management system scope.

91. Why is the Plan phase described before the Do phase in the project?

1. The sequence doesn't have any meaning – Incorrect! Implementation is much more efficient when properly planned.

2. In order to have efficient actions, you need to plan them ahead – Correct!

92. Project milestones are very important for project monitoring and control.

1. True – Correct!

2. False – Incorrect! Project milestones allow the identification and monitoring of important deadlines and the identification of project bottlenecks!

93. Project duration is independent of the organization size.

1. True – Incorrect! Bigger organizations have a bigger scope, more people involved, more interactions. Normally, projects take more time to implement.

2. False – Correct!

94. Why should Communication be a part of the implementation plan?

1. Communication is included in every management system standard – Incorrect! Communication should not be an afterthought in a to-do list. Communication is not about conformity is about effectiveness as a driver of results.

2. Communication in a project is an important driver of results and preemptor of conflicts - Correct!

95. The basic idea behind the use of automation tools is to make your job easier.

1. True – Correct!

2. False – Incorrect! A project represents extra work for team members. Automation tools help team members in writing, communicating and collaborating.

96. The Project Sponsor actively participates in the project.

1. True – Incorrect! The Project Sponsor does not actively participate in the project he can be very useful to unlock resources, reconcile conflicting priorities and escalated issues.

2. False – Correct!

97. Risk anticipation is something that you only do at the beginning of an assignment.

1. True – Incorrect! Risk anticipation is something that should be done continually through the project life cycle.

2. False – Correct!

98. You should you keep a Project File to keep evidence of how the project progressed and was monitored and controlled.

1. True – Correct!

2. False – Incorrect! A project generates a lot of documentation and you want to be able to easily find evidences about the project to support answers about the project with evidence about its development.

99. What kind of characteristics should a Project Plan include (check all that apply)?

1. Contains a description of services to be performed and deliverables of the assignment – Correct!

2. Specifies roles and responsibilities of all those involved in the project – Correct!

3. Presents a first version of the timetable for the project – Correct!

4. It is written and sent for before the proposal approval – Incorrect! It only makes sense to write a Project Plan after the proposal approval.

100. Why is establishing the scope of a project important?

1. Because scope definition is fundamental for project approval – Incorrect! Normally scope definition is decided after project approval.

2. Because top management can decide to exclude some parts of its operations from the scope – Correct!

3. Because scope definition is a technical decision – Incorrect! Scope definition is a management decision.

4. Because scope definition is what motivates project preparation – Incorrect! Scope definition is one of the steps included in project preparation.

101. Why does effective communication speed up project duration?

1. Because effective communication is about a focused project team – Incorrect! Effective communication should be for inside the project team, but also for the external stakeholders, particularly resource controllers and those who are potentially resistant to implementation.

2. Because effective communication maximizes understanding and shortens any feedback cycle time – Correct!

3. Because effective communication maximizes understanding and eliminates the need for monitoring and control meetings about the project – Incorrect! There is always the need for monitoring and control of the project, uncertainty is always present and can affect project implementation.

4. Because effective communication eliminates some stages in the project development – Incorrect! Even the most effective communication does not eliminate stages in the project development.

102. Besides the Project Plan, schedules, and project execution records, no other project documentation is needed.

1. True – Incorrect! Project documentation also includes project control and project ending records, for example.

2. False – Correct!

103. What should a sound Project Plan include?

1. A description of the project deliverables – Correct!

2. The organization chart of the company – Incorrect! While the company is a stable organization, the project is a transient one. So, the Project Plan should include roles for the project.

3. A list of certification bodies – Incorrect! An organization can implement a management system without the aim of certification. Implementation and certification are two different things.

4. The communications channels to be used in case a management system nonconformity is found – Incorrect! Those channels will be defined during project implementation.

104. At the kick-off meeting some other things need to be discussed besides what will be done by whom until when.

1. True – Correct!

2. False – Incorrect! A kick-off meeting should be also about the why, the reason for the project, its importance for the organization.

Module 9 - Implementation of a management system

105. The project will progress with all the work being done through work assignments.
1. **True – Incorrect!** The project will progress with the work done through work assignments and between work assignments.
 2. **False – Correct!**
106. You should regularly follow up on the to-do lists that result from work assignments.
1. **True – Correct!**
 2. **False – Incorrect!** Team members may not be aware of the priority of their tasks and should be warned about the importance of their timely contribution.
107. Working with more than one team in parallel is always the best solution.
1. **True – Incorrect!** Not all organizations have enough resources to be used simultaneously in more than one work front.
 2. **False – Correct!**
108. You, as Project Manager, should avoid being the constraint factor for the progress of the project.
1. **True – Correct!**
 2. **False – Incorrect!** It is not always possible to avoid being the constraint factor. Not being the constraining factor is a comfortable position to be in whenever discussions about time slippage occur.
109. Training is an important tool to help with the implementation of new procedures.
1. **True – Correct!**
 2. **False – Incorrect!** Training is one of the available ways to reduce resistance to change.
110. Should you copy documents from other organizations?
1. **Yes, if they worked before they will work now. – Incorrect!** Every organization is different, even those in the same economic sector.
 2. **Yes, people will love having less work. – Incorrect!** People tend to resist something new that is implemented without their participation.
 3. **No. Every organization is different, and people like to be involved in the development of what affects them. – Correct!**

111. Be particularly aware of answers that are variations of “we’ve always done it this way.”

1. True – Correct!

2. False – Incorrect! Answers of “we’ve always done it this way” normally reveal inefficient and outdated processes.

112. You, the Project Manager, are the one with authority to approve documentation.

1. True – Incorrect! Documentation approval authority should be described in the Project Plan or some other document and will most likely be related with formal hierarchical authority.

2. False – Correct!

113. When introducing changes and new documentation in the day-to-day-activities, resistance to change will probably be the biggest obstacle.

1. True – Correct!

2. False – Incorrect! Normally, people are afraid new things, and dislike not being considered when changes were created/implemented.

114. Work assignments are primarily about documenting practices.

1. True – Incorrect! Work assignments can also include gathering and analyzing information, making recommendations, observing and interviewing.

2. False – Correct!

115. Why implementing documentation is not a linear process?

1. Because many people are involved – Incorrect! The involvement of many people is no reason for a nonlinear process. Organization and planning can help.

2. Because documentation is developed as an iterative process – Correct!

3. Because normally there is no previous documentation – Incorrect! No previous documentation is no reason for a nonlinear process. Even without documentation, an organization can have good practices.

4. Because people have no time for the project – Incorrect! Lack of time is no reason for a nonlinear process, it can extend project duration not its complexity.

116. Resistance to change is a natural reaction during project implementation.

1. True – Correct!

2. False – Incorrect! Being afraid of the new is a natural human reaction that can be managed with communication and preparation

Module 10 - Monitor, control and completing the project

117. Progress in implementing the project must be verified in practice.

1. True – Correct!

2. False – Incorrect! Plans regularly do not survive when they contact reality. You must be sure about what was actually done and the results.

118. Why does an agenda, sent in advance, makes meetings more productive?

1. An advance agenda allows team members who are behind schedule to prepare their defense. – Incorrect! The purpose of sending an agenda in advance is about preparing and focusing participants not about personal politics.

2. An agenda sent in advance puts everybody in the same page, knowing the purpose of the meeting and what is expected from each participant. – Correct!

3. An agenda sent in advance allows team members to overcome problems before the monitor and control meeting. – Incorrect! The purpose of sending an agenda in advance is about the meeting dynamics and not about the project implementation dynamics.

119. Why are monitor and control meetings important?

1. Monitor and control meetings allow management of the implementation project: solving problems, making changes, making decisions, figuring where the project is. - Correct!

2. Monitor and control meetings are important to verify field implementation of new practices. - Incorrect! The status of field implementation of new practices is only an input to the monitor and control meetings.

3. Monitor and control meetings are important to execute critical project assignments. – Incorrect! These meetings are important to manage the implementation project and not to execute the activities of the implementation project.

120. High frequency monitoring of a project is a good thing to do.

1. True – Incorrect! A high frequency can lead to micromanagement problems and waste of time. A low frequency can signal that the project is not important and be of little help to support the implementation.

2. False – Correct!

121. The Project Manager performs audits during project implementation verifications.

1. True – Incorrect! Audits require an independent person to objectively assess the management system implementation according to the standard of reference and internal rules.

2. False – Correct!

122. Internal audits should cover conformity and effectiveness.

1. True – Correct!

2. False – Incorrect! Internal audits can verify if you comply with policies and procedures, but also if those policies and procedures are useful for getting expected results.

123. External auditors will open nonconformities when management reviews discover problems in the management system.

1. True – Incorrect!

2. False – Correct! Unearthing problems in a management system is not a nonconformity. A nonconformity is doing nothing about it, or trying to hide it.

124. Why is the management review meeting important?

1. It is a crucial moment for top management to demonstrate leadership and commitment about the management system. – Correct!

2. It is mandatory to prepare and execute such a meeting. – Incorrect! Preparing and performing a management review meeting should not be about ticking items in to do list. It is an opportunity for top management to demonstrate leadership and commitment to the management system.

3. It is an event where relevant information about the management system is prepared. – Incorrect! A management review meeting allows analysis of previously prepared information to make decisions and take actions, it is not about preparing information.

125. Why is the management review meeting important?

1. It is a crucial moment for top management to demonstrate leadership and commitment about the management system. – Correct!

2. It is mandatory to prepare and execute such a meeting. – Incorrect! Preparing and performing a management review meeting should not be about ticking items in to do list. It is an opportunity for top management to demonstrate leadership and commitment to the management system.

3. It is an event where relevant information about the management system is prepared. – Incorrect! A management review meeting allows analysis of previously prepared information to make decisions and take actions, it is not about preparing information.

126. Why is project closure an important event?

1. The transition from the project phase to permanent functions within the structure of the organization should be planned and executed. – Correct!

2. Project closure is the last event of good project management practices. – Incorrect! Being part of a to-do list is no reason to consider something as important. It is important because, during project closure, you transfer project phase responsibilities to permanent functions in the organization, and you can gather feedback about the overall project implementation to improve your project management skills.

3. Project closure is what management system standards call management review. – Incorrect! Project closure and management review are two different events. Management review decides to accept a management system developed during a project and that decision is the green light to the last stage of the implementation project: its orderly end – that is, its closure.

127. What is the main reason that issuing a project status report is considered good project management practice?

1. Because it helps team members develop their work assignments – Incorrect! Project status report is not about developing work, but about managing resources.

2. Because it helps managing resources – Correct!

3. Because it helps planning work assignments – Incorrect! Project status report is not about planning individual work, but about project progress and managing resources.

4. Because it helps checking actual implementation of management system activities – Incorrect! Project status report is not about checking actual implementation but about checking planned versus actual project activities progression and managing resources.

128. What characterizes productive monitor and control meetings?

1. They are focused on the project status report analysis – Incorrect! Project status report analysis should be done prior to the meeting.

2. They are focused on making decisions – Correct!

3. They do not waste time with questions – Incorrect! Efficiency is not the most important in project management, if there are doubts and questions they should be handled.

4. They are restricted to team members – Incorrect! Monitor and control meetings are for project stakeholders and occasionally can include guests because of specific issues that should be handled.

129. A key topic at the management review agenda is evaluating past performance.

1. True – Incorrect! A management review agenda should include the evaluation of past performance, but also assess whether policies and objectives remain updated, and to establish guidance for future performance.

2. False – Correct!

Module 11 - Taking the organization for the certification

130. Only a certified management system brings benefits.

1. True – Incorrect! Implementing a management system already brings some benefits. They can be complemented by other benefits derived from certification.

2. False – Correct!

131. Certification can bring marketing benefits.

1. True – Correct!

2. False – Incorrect! Sometimes certification is a pre-condition for participation in tenders for some customers or projects.

132. Choosing a Certification Body is, above all, a question of price.

1. True – Incorrect! Price is important, but what about the reputation of the Certification Body? What about their specialization? What about the requirements of your major markets?

2. False – Correct!

133. A certification process has two steps.

1. True – Incorrect! A certification process has three steps (stage 1 audit, stage 2 audit and Surveillance audits).

2. False – Correct!

134. Stage 1 audit is used to check if operations are performed according to the standard and internal documentation.

1. True – Incorrect! A Stage 1 audit is to check if the scope of certification is clear and doesn't present misleading information, and to review the management system documentation.

2. False – Correct!

135. Certification is only granted when the certification audit doesn't find non-conformances.

1. True – Incorrect! Minor non-conformance will not prevent certification. Verification and closure of minor non-conformance will take place at the next routine surveillance visit.

2. False – Correct!

136. Surveillance audits must be conducted at least once every three years.

1. True – Incorrect! Surveillance audits must be conducted at least once a year.

2. False – Correct!

137. A management review of the management system needs to happen before the certification body audit. This ensures that it is meeting requirements and re-assigning resources as necessary.

1. True – Correct!

2. False – Incorrect! The certification body doesn't want to audit a management system that the top management hasn't had a chance to review.

138. Auditors will only use the ISO standards to prepare for the audit.

1. True – Incorrect!

2. False – Correct! As an example, the audit team can ask for the management system manual if it exists, for the policy and objectives of the management system, for a list of the documented information relevant for the management system and for a list of standards, legislation and other external rules relevant for the organization's management system.

139. Auditors are trying to verify compliance, not to find something wrong.

1. True – Correct!

2. False – Incorrect! The purpose of a certification audit is to assess if a management system is working according to the reference documents and is being improved.

140. The certification auditor cannot raise a nonconformity if he didn't find the requirement in the standard or in your documentation.

1. True – Correct!

2. False – Incorrect! Certification auditors always work with a reference like standards, legislation or documentation from the audited organization.

141. When reporting a nonconformity, the auditor must include the cause.

1. True – Incorrect! The cause should be investigated by the audited organization and is the base for a sound corrective action.

2. False – Correct!

142. Choosing a certification body is a simple process because the cheapest quote should be accepted.

1. True – Incorrect! Choosing a certification body is the result of considering other parameters besides price: certification body reputation, experience, specialization, etc.

2. False – Correct!

143. An organization should close all corrective actions raised internally before the certification audit.

1. True – Incorrect! There is no need to have all corrective action requests closed before the certification audit.

2. False – Correct!

144. An organization can ask the certification auditor how to resolve a nonconformity raised by this auditor.

1. True – Incorrect! An organization may ask, but the auditor should not give an answer because this would be a conflict of interest.

2. False – Correct!

Module 12 - Maintaining the certification

145. Getting the certification is the final prize at the end of a race.

1. True – Incorrect! Certification isn't a one-time event, it must be renewed every year.

2. False – Correct!

146. Why is Monitoring and Control so important in a management system?

1. To answer to a management system standard requirement – Incorrect! A Monitoring and Control function working properly promotes the improvement of a management system.

2. To show to auditors that operations are under control – Incorrect! A correctly operating Monitoring and Control function promotes much more than control. It promotes the improvement of a management system.

3. A correctly working Monitoring and Control function promotes the improvement of a management system – Correct!

147. Correction and corrective action are different words for the same meaning.

1. True – Incorrect! Correction acts upon the non-conformity. Corrective action acts upon the cause(s) of the non-conformity.

2. False – Correct!

148. Double loop learning questions whether or not operating policies and objectives are appropriate.

1. True – Correct!

2. False – Incorrect! Operating policies and objectives are not valid forever. From time to time they should be challenged with what was learned.

149. Communication nurtures a culture of improvement, openness and participation.

1. True – Correct!

2. False – Incorrect! Without communication, people don't know what is relevant, don't know the results, don't build-up cause-and-effect relationships, and can't give timely contributions.

150. Top management daily examples of complying with the management system are very important.

1. True – Correct!

2. False – Incorrect! Top management examples through actions sets a standard for everyone in the organization.

151. When circumstances change, policies and procedures may have to change.

1. True – Correct!

2. False – Incorrect! New laws, new products, new services, new segments of customers, new business models, new distribution channels, and new performance challenges are all examples of what can promote changes in the policies and procedures.

152. When circumstances change, competencies may have to change.

1. True – Correct!

2. False – Incorrect! New laws, new products, new services, new segments of customers, new business models, new distribution channels, and new performance challenges are examples of what can promote the need to improve existing or acquiring new competences.

153. Bad suppliers must be expelled from a management system.

1. True – Incorrect! Your organization has an option to work with bad suppliers to make them improve their own performance.

2. False – Correct!

154. When circumstances change, risks may change.

1. True – Correct!

2. False – Incorrect! New laws, new products, new services, new segments of customers, new business models, new distribution channels, and new performance challenges are examples of things that can generate new risks or change the importance of the existing ones.

155. Relevant external documents for the management system do not change with time.

1. True – Incorrect!

2. False – Correct! Each organization must set a process for being aware of new or revised external documentation relevant for the management system.

156. After the certification audit the organization doesn't have to focus as much on its management system.

1. True – Incorrect! Certification is not a prize or a one-time event. Next year you will have a surveillance audit and have to show an operating and improved management system.

2. False – Correct!

157. Incorrect use of logo of the certification body can lead to your certification being withdrawn.
1. True – Correct!
 2. False – Incorrect! The guidelines for the use of the logo of a certified organization mention the loss of certification because of misuse.
158. Management review is critical for aligning the management system and business challenges and objectives.
1. True – Correct!
 2. False – Incorrect! Without alignment with business results and challenges, and without top management participation and commitment, your management system will become a burden.
159. In a surveillance audit, the auditor always looks at key activities (such as management review, internal audit, corrective actions and complaint handling).
1. True – Correct!
 2. False – Incorrect! Surveillance audits don't audit everything like in the certification audit, but key activities (such as management review, internal audit, corrective actions and complaint handling) are always audited.
160. What is the main reason not to consider certification a one-time event?
1. Because maintaining certification requires keeping an updated management system – Correct!
 2. Because after the certification comes the surveillance audits – Incorrect! An effective management system is a continuous job not something to pass at a set of external evaluations.
 3. Because surveillance audits evaluate if the management system is being followed – Incorrect! Keeping certification is important, but keeping an effective management system is even more important, and an effective management system requires constant work.
 4. Because certification requires periodically sending information to the certification body – Incorrect! There is no need for periodically sending information to certification bodies. Most importantly, you want a management system that continuously deliver results.
161. What is the main purpose of surveillance audits?
1. Surveillance audits allow certification bodies to audit all processes and sites at least once during the three-year surveillance cycle – Correct!
 2. Surveillance audits allow certification bodies to repeat the certification audit annually – Incorrect! Certification and surveillance audits are different both in intent and duration.

3. Surveillance audits allow certification bodies to check if corrective actions are developed – Incorrect! Surveillance audits are used to check much more than only corrective actions development.

4. Surveillance audits are used to prepare organizations to certification audits – Incorrect! Surveillance audits are used to monitor management systems after the certification audit.